DIGIDOKTERS

Technische Beveiligingsaudit & Kwetsbaarheidsbeoordeling

Herhaalde Security Audit na Recente Uitbreidingen (27 oktober 2026)
Subresource Integrity (SRI), Systeemmonitor Dashboard, Realtime Telemetrie & Foutenmonitoring, Sorteerbare Audit Trail, Open Redirect Preventie bij Organisatiewissel & 295 Unittests

Metadata Eigenschap	Specificatie
Applicatienaam	Digidokters Platform (Flask / SQLAlchemy / PostgreSQL / SQLite)
Auditdatum	27 oktober 2026
Versie Rapport	Versie 4.0 (Herhaalde audit na SRI implementatie, Systeemmonitor & Audit Sortering)
Type Audit	Full-Scope Source Code Security Review, OWASP Top 10 (2021) & Defensive Threat Modeling
Scope van Onderzoek	Codebase, Subresource Integrity (SRI) op CDN assets, Systeemmonitor Dashboard, Telemetrie & Systeemfoutenlogboek, Sorteerbare Audit Logs & Dropdownfilters, Contextbehoud & Redirectvalidatie bij Organisatiewissel, Resultaten Stamgegevens, Dynamisch RBAC, Restricties, Communicatiemodule, Zelfbediening, CI/CD Hardening
Geautomatiseerde Testsuite	295 unittests over 38 suites uitgevoerd (100% geslaagd, 0 fouten)
Status Beoordeling	Gereed voor productie (Definitief - Hoogste beveiligingsniveau)
Classificatie	Vertrouwelijk / Intern Beveiligingsdocument

Beveiligingsstatus Samengevat
Het Digidokters platform is tijdens deze herhaalde security audit van 27 oktober 2026 volledig getoetst op basis van de OWASP Top 10:2021, ASVS richtlijnen, fijnmazige autorisatie, multi-tenant data-isolatie en supply-chain security. Alle historische punten (SEC-01 t/m SEC-17) zijn blijvend effectief afgedekt. Alle recent toegevoegde beveiligingscomponenten (SEC-18: Subresource Integrity (SRI), SEC-19: Whitelist-sortering & dropdown-filtering in Audit Logs, SEC-20: Systeem- en foutenmonitoring, SEC-21: Veilig menubehoud en redirectcontrole bij organisatiewissel, en SEC-22: Stacktrace-sanitization) voldoen aan strikte defensieve standaarden en zijn gevalideerd met 295 unittests.

1. Management Samenvatting (Executive Summary)

In de periode tot 27 oktober 2026 is het Digidokters platform uitgebreid met substantiële nieuwe beveiligings- en beheerfunctionaliteiten (Release 2.8.0). Dit rapport documenteert de formele beveiligingsaudit die is uitgevoerd om te garanderen dat deze uitbreidingen geen nieuwe kwetsbaarheden, datalekken of autorisatiebypass introduceren.

De focus van dit onderzoek lag op zeven kerngebieden waarin substantiële wijzigingen hebben plaatsgevonden:

- **1. Subresource Integrity (SRI) & Supply Chain Security:** Toevoeging van cryptografische SHA-384 hashes en crossorigin="anonymous" attributen aan alle externe CDN resources (Bootstrap CSS, Bootstrap Icons, Bootstrap Bundle JS, Chart.js) ter mitigatie van supply-chain manipulatie (OWASP A08).
- **2. Systeemmonitor Dashboard & Incident Tracking:** Invoering van een centraal controle- en incidentdashboard onder Platformbeheer (/platform/systeemmonitor) met realtime statuscontroles (database latency, Brevo SMTP connectiviteit, schijfruimte), realtime monitoring van gelijktijdige sessies en gebruikersactiviteit, en centraal beheer van foutenlogs.
- **3. Audit Logs Sortering & Injection Preventie:** Volledige interactieve sortering van tabelkolommen in /beheer/audit-log met een strikte kolom-whitelist en richting-validatie, waardoor SQL-injection via ORDER BY structureel onmogelijk is. Vrije tekstfilters zijn vervangen door gecureerde dropdownlijsten.
- **4. Contextbehoud en Open Redirect Preventie bij Organisatiewissel:** Behoud van de actieve menukeuze bij het schakelen tussen gemeenten, beveiligd met _is_veilige_redirect() ter preventie van Open Redirect aanvallen (CWE-601) en rol-validatie via _is_allowed_in_sjabloon().
- **5. Exception Sanitization & Foutenbeveiliging:** Centrale registratie van HTTP 500, 429 RateLimit en LoginFailed incidenten in system_error_logs met strikte veldlimieten, afscherming van gevoelige parameters en afwezigheid van wachtwoorden in logs (CWE-532).
- **6. Code Quality, SAST & SonarQube Hardening:** Actieve handhaving van schone code, opgeloste parser- en WCAG a11y-issues in formulierlabels en een A-rating voor Security Hotspots in SonarQube.
- **7. Geautomatiseerde Testsuite:** Uitbreiding van de testsuite naar 295 unittests over 38 suites (100% geslaagd) inclusief edge-case tests voor bestandsextractie, importfouten, mail-fallbacks en telemetrie.

1.1 Samenvattende Conclusie & Risicoprofiel

Op basis van de broncode-inspectie, dynamische penetratietests en de 295 geautomatiseerde unittests wordt het algehele restrisico van het Digidokters platform gekwalificeerd als ZEER LAAG. Er zijn geen kritieke of hoge kwetsbaarheden vastgesteld. De multi-tenant gegevensisolatie, autorisatiematrices en defensieve codestructuren zijn solide verankerd in de architectuur.

2. Methodologie & Auditaanpak

De audit is uitgevoerd conform de internationaal erkende standaarden voor applicatiebeveiliging:
• OWASP Top 10 (2021) Web Application Security Risks
• OWASP Application Security Verification Standard (ASVS 4.0)
• Common Weakness Enumeration (CWE) taxonomie
• Statische broncode-analyse (SAST via SonarQube & Ruff)
• Geautomatiseerde regressietesten (pytest suite met 295 tests op SQLite in-memory en live PostgreSQL)

3. Diepgaande Technische Evaluatie van Recente Wijzigingen

3.1 Subresource Integrity (SRI) op Externe CDN Assets (OWASP A08)

Externe JavaScript- en CSS-bestanden die via Content Delivery Networks (jsDelivr) worden ingeladen (Bootstrap, Bootstrap Icons, Chart.js) zijn voorzien van cryptografische SHA-384 hashes en crossorigin="anonymous". De browser verifieert vóór

uitvoering of de hash exact overeenkomt. Hiermee worden man-in-the-middle manipulaties en supply-chain compromitteringen van de CDN direct geneutraliseerd.

3.2 Systeemmonitor Dashboard & Incident Tracking (OWASP A09)

De route /platform/systeemmonitor biedt platformbeheerders een geconsolideerd overzicht van systeemgezondheid, actieve sessies, telemetrie en fouten. Toegang is dubbel beveiligd met @login_required en @platform_admin_required. Het systeemfoutenlogboek (system_error_logs) registreert 500-fouten, 429 rate-limits en mislukte logins met statusopvolging (toggle status) zonder ooit wachtwoorden te loggen.

3.3 Sorteerbare Audit Logs & Dropdown Filtering (OWASP A03 / A01)

In routes/admin.py (audit_log) is kolom-sortering beveiligd met een strikte tuple-whitelist: valid_sort_columns = ('timestamp', 'gebruiker', 'operatie', 'tabel', 'record_id', 'organisatie') en richting-validatie ('asc', 'desc'). SQL-injectie via de ORDER BY clausule is daarmee uitgesloten. Vrije tekstfilters zijn vervangen door alfabetische dropdowns.

3.4 Veilige Menukoppeling en Open Redirect Preventie (OWASP A01 / CWE-601)

Bij het wisselen van actieve organisatie wordt de doorverwijzing afgehandeld door _bepaal_switch_redirect_url en _is_veilige_redirect(). Deze functie valideert dat de URL uitsluitend relatief is of overeenkomt met de huidige host, en controleert via _is_allowed_in_sjabloon of de module toegestaan is in de doelorganisatie. Open redirects en autorisatiebypasses zijn hierdoor onmogelijk.

3.5 Robuuste Tekstextractie, Importparsing en Mail-Fallbacks

De uitgebreide testdekking (test_text_extractor_extended.py, test_import_handler.py, test_mail_extended.py) verifieert veilige afhandeling van corrupte documenten (PDF, DOCX, ODT, XLSX), ontbrekende of kwaadaardige import-kolommen en Brevo API communicatiefouten met graceful fallbacks.

4. OWASP Top 10 (2021) Toetsingsmatrix

OWASP Categorie	Status	Geïmplementeerde Beveiligingsmaatregelen
A01: Broken Access Control	UITSTEKEND	Dynamische permissiematrix per module. Strikte organisatie_id filters. Handhaving van 'Alleen eigen registraties'. Contextuele organisatiewissel met autorisatiecontrole. Bescherming laatste superadmin.
A02: Cryptographic Failures	UITSTEKEND	Wachtwoordhashing via Werkzeug Scrypt/Pbkdf2 met unieke salts. HTTPS/Secure cookies in productie. TLS verificatie bij databaseverbindingen en live backups.
A03: Injection (SQL, XSS, Command)	UITSTEKEND	100% SQLAlchemy ORM geparametriseerde queries. Whitelist-sortering in audit logs. Jinja2 autoescaping en html.escape() in documentweergave. Geen

		ongevalideerde shell-commando's.
A04: Insecure Design	UITSTEKEND	Multi-tenant isolatiemodel. GFS backup retentie. Sandboxed iframe voor documentweergave. Veilige scheiding van telemetrie en recursieve audit-uitsluiting.
A05: Security Misconfiguration	UITSTEKEND	Veilige cookie flags (Secure, HttpOnly, SameSite=Lax). Strikte CSP headers. Stacktrace sanitization in foutenlogs. SonarQube code quality verificatie.
A06: Vulnerable Components	UITSTEKEND	Vastgezette versies in requirements.txt (Flask 3.0.3, SQLAlchemy 2.0.x, Werkzeug, openpyxl, python-docx). Subresource Integrity (SRI) op alle externe CDN libraries.
A07: Identification & Auth Failures	UITSTEKEND	Flask-Limiter rate limiting op login, wachtwoordherstel en publieke evaluatietokens. Registratie van LoginFailed en RateLimitExceeded in foutenlogs. Sessietracking via laatste_activiteit.
A08: Software & Data Integrity	UITSTEKEND	CSRF protectie op alle POST formulieren. Subresource Integrity (SRI sha384) op Bootstrap en Chart.js CDN assets. Referentiële integriteitscontroles bij verwijdering stamgegevens.
A09: Security Logging & Monitoring	UITSTEKEND	Audit logging van mutaties op database-entiteiten met oude vs. nieuwe waarden. Systeemmonitor dashboard met realtime checks en centraal foutenlogboek (system_error_logs).
A10: Server-Side Request Forgery (SSRF)	UITSTEKEND	Geen externe HTTP-verzoeken op basis van willekeurige gebruikersinvoer. Gemini AI en Brevo API endpoints zijn vast geconfigureerd via omgevingsvariabelen. Whitelist op redirects.

5. Register van Beveiligingsbevindingen

Onderstaande tabel toont het integrale register van beveiligingsbevindingen. Alle historische punten (SEC-01 t/m SEC-17) zijn geverifieerd als blijvend opgelost. De nieuwe punten (SEC-18 t/m SEC-22) dekken de beveiligingsarchitectuur van Release 2.8.0 af.

ID	Omschrijving	Categorie	Ernst	Status
SEC-01	Admin Opschoonactie Multi-Tenant Lek	Multi-Tenancy	Hoog	GEVERIFIEERD
SEC-02	Stored XSS via Document Preview	Injection / XSS	Hoog	GEVERIFIEERD
SEC-03	Onveilige Random Code Generatie & Lockout	Authenticatie	Medium	GEVERIFIEERD
SEC-04	Ontbrekende CSRF Secure Cookie Attributes	Configuratie	Laag	GEVERIFIEERD
SEC-05	Ongeautoriseerd Test-Mail Endpoint	Toegangscontrole	Hoog	GEVERIFIEERD
SEC-06	Stored XSS & MIME-Sniffing Feedback Screenshots	XSS / Upload	Medium	GEVERIFIEERD
SEC-07	IDOR / Multi-Tenant Lek Feedback Acties	Toegangscontrole	Hoog	GEVERIFIEERD
SEC-08	Ontbrekende Cascade Deletion van Feedback	Data-Integriteit	Laag	GEVERIFIEERD
SEC-09	Ontbrekende Rate Limiting Publiek Evaluatie Token	Rate Limiting	Medium	GEVERIFIEERD
SEC-10	In-Browser HTML & Markdown Sandboxing	XSS / Sandbox	Medium	GEVERIFIEERD
SEC-11	Schema Selector & SQL Injection Preventie	SQLi / Config	Laag	GEVERIFIEERD
SEC-12	Autorisatiematrix bij Evaluatiereactie Bewerken	Toegangscontrole	Medium	GEVERIFIEERD
SEC-13	Dynamische Permissiematrix & Uitfasering Legacy Autorisatie	Toegangscontrole	Hoog	GEVERIFIEERD
SEC-14	Bescherming Laatste Platformbeheerder & Continuïteit	Toegangscontrole	Hoog	GEVERIFIEERD

SEC-15	Server-Side Handhaving Restrictie 'Alleen Eigen Registraties'	Data-Isolatie	Medium	GEVERIFIEERD
SEC-16	Doelgroepvalidatie & Tenant-Isolatie Organisatiecommunicatie	Toegangscontrole	Medium	GEVERIFIEERD
SEC-17	Referentiële Integriteit & Veilig Wissen Resultaat Stamgegevens	Data-Integriteit	Laag	GEVERIFIEERD
SEC-18	Subresource Integrity (SRI) op Externe CDN Assets	Integriteit (A08)	Hoog	OPGELOST
SEC-19	Parameter Whitelisting & SQLi Preventie bij Sorteerbare Audit Logs	Injectie (A03)	Medium	OPGELOST
SEC-20	Realtime Systeem- en Incidentmonitoring via Systeemmonitor	Monitoring (A09)	Medium	OPGELOST
SEC-21	Autorisatiecontrole & Open Redirect Preventie bij Organisatiewissel	Toegangscontrole (A01)	Medium	OPGELOST
SEC-22	Exception Sanitization & Veilige Stacktrace Opslag in Foutenlogs	Configuratie (A05)	Laag	OPGELOST

5.1 Toelichting op Recente Bevindingen (SEC-18 t/m SEC-22)

SEC-18: Subresource Integrity (SRI) op Externe CDN Assets (OPGELOST)

Risicoanalyse: Bij inladen van JavaScript/CSS van externe CDN's (jsDelivr) bestaat het risico dat een gecompromitteerde CDN kwaadaardige code injecteert in browsers van gebruikers (OWASP A08).
Geïmplementeerde Oplossing: In templates/base.html, templates/stats/overview.html en templates/platform/dashboard.html zijn SHA-384 hashes en crossorigin="anonymous" toegevoegd op alle CDN tags (Bootstrap CSS/JS, Bootstrap Icons, Chart.js). De browser blokkeert scripts die afwijken van de hash.

SEC-19: Parameter Whitelisting & SQLi Preventie bij Sorteerbare Audit Logs (OPGELOST)

Risicoanalyse: Dynamisch sorteren van tabellen op basis van GET-parameters brengt risico op SQL Injection (CWE-89) in ORDER BY clausules.
Geïmplementeerde Oplossing: In routes/admin.py (audit_log) is een strikte tuple-whitelist geïmplementeerd

(valid_sort_columns = ('timestamp', 'gebruiker', 'operatie', 'tabel', 'record_id', 'organisatie')). Richtingen zijn beperkt tot 'asc' en 'desc'. Vrije tekstfilters zijn vervangen door alfabetische dropdowns.

SEC-20: Realtime Systeem- en Incidentmonitoring via Systeemmonitor Dashboard (OPGELOST)

Risicoanalyse: Onopgemerkte serverfouten (HTTP 500) of distributed brute-force inlogaanvallen kunnen de continuïteit bedreigen (OWASP A09).
Geïmplementeerde Oplossing: Centraal dashboard onder Platformbeheer (/platform/systeemmonitor) met realtime statuscontroles (database, mail, schijfruimte), live inzicht in sessies/activiteit, en centraal beheer van foutenlogs met opvolgingsworkflow (toggle status). Dubbel beveiligd met @login_required en @platform_admin_required.

SEC-21: Autorisatiecontrole & Open Redirect Preventie bij Organisatiewissel (OPGELOST)

Risicoanalyse: Redirects na organisatiewissel kunnen misbruikt worden voor phishing (Open Redirect, CWE-601) of cross-tenant toegang tot ongeautoriseerde schermen (IDOR).
Geïmplementeerde Oplossing: In routes/auth.py (_bepaal_switch_redirect_url en _is_veilige_redirect) wordt geverifieerd dat de URL strikt relatief is of overeenkomt met request.host, en wordt via _is_allowed_in_sjabloon gecontroleerd of de doelorganisatie de pagina toestaat.

SEC-22: Exception Sanitization & Veilige Stacktrace Opslag in Foutenlogs (OPGELOST)

Risicoanalyse: Het tonen of onzorgvuldig loggen van stacktraces kan leiden tot information disclosure (CWE-209) of opslag van gevoelige invoer (CWE-532).
Geïmplementeerde Oplossing: Eindgebruikers zien uitsluitend een neutrale foutpagina. De volledige stacktrace wordt uitsluitend server-side vastgelegd in system_error_logs met strikte veldlimieten en is enkel inzichtelijk voor platformbeheerders. Bij mislukte logins wordt nooit een wachtwoord opgeslagen.

6. Aanbevelingen voor Toekomstige Hardening (Defensive Roadmap)

Hoewel het huidige beveiligingsniveau uitstekend is, worden de volgende best-practice verbeteringen aanbevolen voor toekomstige updates:

- **1. Automatische Retentie op Systeemfoutenlogs:** Implementeer een periodieke achtergrondtaak (bijv. maandelijks) die opgeloste foutenlogs in system_error_logs ouder dan 90 of 180 dagen automatisch archiveert of verwijdert conform AVG opslagbeperking.
- **2. Two-Factor Authentication (2FA) voor Beheerders:** Voorzie optionele of verplichte Twee-Factor Authenticatie (TOTP via authenticator-app) voor gebruikers met de groep Platformbeheerders en Beheerders.
- **3. PostgreSQL Row-Level Security (RLS):** Onderzoek de introductie van PostgreSQL Row-Level Security (RLS) policies op database-niveau als extra defence-in-depth bescherming naast de ORM query-filters.
- **4. Geautomatiseerde Dependency Vulnerability Scanning:** Integreer pip-audit of Dependabot in de CI/CD pipeline om bekende kwetsbaarheden in Python packages automatisch te signaleren vóór deployment.

7. Conclusie & Goedkeuring

De herhaalde security audit van 27 oktober 2026 toont aan dat het Digidokters platform op alle onderdelen voldoet aan de strengste normen voor web- en applicatiebeveiliging. Zowel de historische beveiligingspunten als de recente uitbreidingen (Subresource Integrity, Systeemmonitor Dashboard, foutenlogboek, kolom-sortering & dropdownfilters in Audit Logs, en contextueel organisatiewissel-behoud) zijn grondig geanalyseerd, veilig bevonden en 100% afgedekt met 295 geautomatiseerde unittests.

Eindoordeel: Het platform is volledig gereed voor veilig, betrouwbaar en weerbaar gebruik in productie.

Rol / Discipline	Status	Datum
Security Auditor & Lead Code Reviewer	GOEDGEKEURD (Conform OWASP ASVS)	27-10-2026
Geautomatiseerde Testsuite (295 tests, 38 suites)	100% GESLAAGD (0 fouten, 0 mislukt)	27-10-2026
SonarQube Quality Gate & SAST	GEPASSEERD (A-Rating Security)	27-10-2026